

# Control Implementation Guide

---

*Civil Society Anti-Money Laundering & Financial Intelligence Framework*

**Version 0.1 | Normative Implementation Guide**

## Status

This document is an official derivative specification of CS-AML Framework v0.1. It defines how the minimum CS-AML control catalogue is to be implemented, evidenced, tested, reviewed, and improved. It does not replace applicable law, professional ethics, or organisational policy.

# Document Control

| Field                  | Specification                                                                                                                                        |
|------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|
| Document               | CS-AML Control Implementation Guide                                                                                                                  |
| Version                | 0.1                                                                                                                                                  |
| Status                 | Normative derivative / implementation baseline                                                                                                       |
| Parent                 | CS-AML Framework v0.1                                                                                                                                |
| Related specifications | Goals & Non-Goals; Typology Catalogue; Investigation Methodology; Data Model Specification                                                           |
| Primary audience       | CSO leadership, investigators, compliance/ethics leads, privacy/security staff, system owners, reviewers, assurance teams                            |
| Normative language     | SHALL/MUST = mandatory; SHOULD = strongly recommended unless justified; MAY = optional                                                               |
| Control population     | 26 minimum controls inherited from the CS-AML v0.1 control catalogue                                                                                 |
| Design objective       | Make controls operational, proportionate, auditable, and outcome-focused without turning civil-society investigation into regulated-bank compliance. |

## 1. Purpose and Scope

The CS-AML Control Implementation Guide translates the normative control catalogue into operating controls that a civil-society organisation can actually perform and demonstrate. It defines the expected control objective, implementation pattern, responsible roles, operating evidence, test procedures, common failure modes, and maturity expectations for each minimum control.

### Primary implementation principle

A control is not implemented merely because a policy exists. A conforming control requires an assigned owner, an operating process, evidence that the process occurred, and a means to test whether the control materially reduces the risk it was designed to address.

### 1.1 In scope

- Governance and accountability controls
- Case initiation and lifecycle-gate controls
- Source, evidence, and provenance controls
- Entity, relationship, asset, and value-flow analytical controls
- Typology, hypothesis, assessment, and intelligence-gap controls
- Privacy, retention, and source-protection controls

- Security and access controls
- Quality, dissemination, and audit controls
- Technology, AI, and explainability controls
- Control testing, exceptions, assurance, metrics, and maturity

## 1.2 Out of scope

- Bank/financial-institution AML regulatory compliance programmes
- Formal STR/SAR filing obligations unless separately applicable
- Law-enforcement covert powers or compelled financial records
- A determination of criminal guilt
- Vendor-specific product configuration
- A requirement to collect more personal or financial data than is necessary for a legitimate civil-society investigation

## 2. Control Philosophy and External Alignment

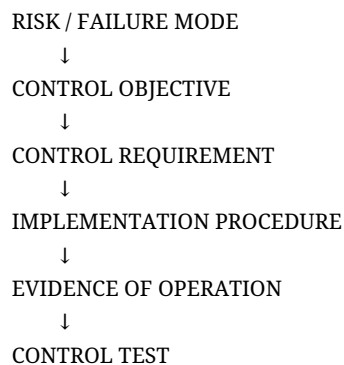
CS-AML uses a risk-based implementation philosophy. Controls SHALL be proportionate to the case, data, harm, dissemination, and technology risks involved. Organisations SHOULD prioritise controls that materially improve analytical reliability, rights protection, source safety, and decision usefulness rather than maximising documentation volume.

### Outcome orientation

CS-AML borrows the logic of proportionality, prioritisation, and effectiveness from contemporary financial-crime risk management, while adapting it to civil society. The objective is not “more controls”; it is better-supported intelligence with fewer avoidable harms.

The guide is consistent in principle with the FATF emphasis on risk-based and effective AML/CFT systems, the Wolfsberg Group’s 2026 articulation of proportionality, prioritisation, and effectiveness, and PPATK’s recognition that high-quality information from NGO/CSO and the public can support financial-intelligence analysis. These sources provide context; CS-AML remains a civil-society methodology rather than a financial-institution compliance standard.

## 3. CS-AML Control Model



↓  
EFFECTIVENESS JUDGMENT  
↓  
REMEDATION / IMPROVEMENT

### 3.1 Control design attributes

| Attribute             | Definition                                                         |
|-----------------------|--------------------------------------------------------------------|
| Control ID            | Stable reference identifier from the CS-AML control catalogue.     |
| Objective             | The result the control is intended to achieve.                     |
| Requirement           | The minimum normative rule.                                        |
| Risk addressed        | The error, harm, abuse, or analytical failure controlled.          |
| Owner                 | Role accountable for design and/or operation.                      |
| Frequency/trigger     | When the control is performed.                                     |
| Procedure             | Minimum operating steps.                                           |
| Evidence of operation | Artefacts demonstrating that the control actually ran.             |
| Test procedure        | How assurance personnel verify design and operating effectiveness. |
| Failure modes         | Known patterns indicating ineffective or cosmetic implementation.  |
| Exception path        | How deviations are approved, time-limited, and compensated.        |
| Metric                | Evidence used to understand coverage, timeliness, or outcomes.     |

## 4. Roles, Accountability, and Segregation of Duties

| Role                                    | Minimum accountability                                                                          |
|-----------------------------------------|-------------------------------------------------------------------------------------------------|
| Governing authority / executive sponsor | Approves organisational adoption, risk tolerance, material exceptions, and assurance responses. |
| Framework owner                         | Maintains CS-AML local policy, control catalogue, mappings, and change management.              |
| Case owner                              | Accountable for legitimate purpose, scope, risk, gates, resources, and closure of a case.       |
| Lead analyst                            | Directs analysis and ensures provenance, hypotheses, gaps, and confidence are maintained.       |
| Collector / researcher                  | Obtains and registers information through lawful, approved methods.                             |
| Evidence custodian / data steward       | Maintains integrity, lineage, storage, retention, and                                           |

| Role                              | Minimum accountability                                                                          |
|-----------------------------------|-------------------------------------------------------------------------------------------------|
|                                   | controlled data quality.                                                                        |
| Privacy / legal / ethics reviewer | Advises on necessity, proportionality, sensitive data, publication risk, and legal constraints. |
| Security administrator            | Implements access, authentication, logging, source compartmentalisation, and incident response. |
| Peer reviewer / red-team reviewer | Independently challenges evidence, reasoning, alternatives, confidence, and wording.            |
| Product approver                  | Authorises referral, publication, partner dissemination, or other external release.             |
| Assurance reviewer                | Tests control design/operation independently from day-to-day case execution.                    |
| Technology/model owner            | Owns rules, models, AI integrations, versioning, validation, and technical controls.            |

### Segregation rule

A high-impact adverse assessment **SHOULD NOT** be authored, independently reviewed, and finally approved by the same individual. Small organisations **MAY** use documented compensating controls such as cross-organisation peer review or executive review when full role separation is impracticable.

## 5. Risk-Based Control Profiles

| Profile                             | Typical conditions                                                                                                                                                                               | Control expectation                                                                                                                                                                  |
|-------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| P1 — Standard                       | Ordinary open-source research; limited sensitive data; no protected source; no planned public allegation.                                                                                        | All mandatory controls; streamlined gate and review evidence.                                                                                                                        |
| P2 — Sensitive                      | Sensitive personal/financial data, vulnerable persons, confidential source, significant reputational impact, or cross-border sharing.                                                            | Mandatory controls plus privacy/security review, stricter access, enhanced evidence handling, independent peer review.                                                               |
| P3 — High Impact                    | Public attribution of serious wrongdoing, referral likely to trigger enforcement, protected-source risk, large-scale datasets, high-threat subject, or significant physical/digital safety risk. | Enhanced gate approvals, independent review/red-team, legal/ethics review where appropriate, formal dissemination control, documented disconfirmation, stronger audit and assurance. |
| P4 — Technology/Automation Enhanced | Material use of AI/ML, large-scale entity resolution, automated scoring, or automated extraction that can influence findings.                                                                    | P1-P3 as applicable plus TEC-01/02 validation, model/rule cards, human verification, versioning, and performance monitoring.                                                         |

# 6. Control Implementation Lifecycle

## 1. Establish

Approve local CS-AML policy, owner, scope, roles, control catalogue, risk profiles, and exceptions process.

## 2. Design

Translate each normative control into an operating procedure, system configuration, form/template, and expected evidence.

## 3. Implement

Train personnel, configure systems, run controls on live or pilot cases, and collect evidence of operation.

## 4. Validate

Verify that each control exists, can be performed, and maps to the intended risk and framework requirement.

## 5. Test

Perform design-effectiveness and operating-effectiveness tests on a risk-based sample.

## 6. Measure

Track coverage, timeliness, exceptions, false-positive/false-association outcomes, privacy events, and review findings.

## 7. Improve

Remediate failures, simplify redundant controls, strengthen high-value controls, and update for emerging typologies and technology risks.

# 7. Evidence of Control Operation

Evidence of operation demonstrates that a control actually ran. A policy, template, or configured feature is design evidence; it is not by itself evidence that the control operated on a case.

| Evidence class     | Examples                                                                                                                                                |
|--------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------|
| Design evidence    | Policy, procedure, template, role description, configured workflow, model/rule card.                                                                    |
| Operation evidence | Completed charter, source record, hash record, merge decision, gate approval, hypothesis matrix, review sign-off.                                       |
| System evidence    | Audit event, IAM record, immutable log, version record, retention job output, model execution/version.                                                  |
| Outcome evidence   | Unsupported relationship removed, overstatement corrected, source identity protected, duplicate entities resolved, dissemination prevented or narrowed. |
| Assurance evidence | Test sample, finding, rating, remediation plan, retest                                                                                                  |

| Evidence class | Examples |
|----------------|----------|
|                | result.  |

## 8. Control Testing Standard

### 8.1 Design effectiveness

A control is design-effective when, if performed as specified, it is reasonably capable of achieving its control objective and reducing the stated risk without creating disproportionate harm.

### 8.2 Operating effectiveness

A control is operating-effective when evidence shows it was performed by appropriate personnel, at the required time, on the relevant population, and exceptions were identified and handled.

### 8.3 Minimum test method

1. Define the control population and period.
2. Select a risk-based sample; include high-impact and exception cases.
3. Inspect evidence of operation and timing.
4. Reperform or independently verify a meaningful portion of the control when feasible.
5. Identify exceptions and determine whether they are isolated or systemic.
6. Rate design and operating effectiveness separately.
7. Assign remediation owner/date and retest material failures.

### 8.4 Effectiveness rating

| Rating                     | Meaning                                                                            |
|----------------------------|------------------------------------------------------------------------------------|
| Effective                  | Control is appropriately designed and operated with no material exception.         |
| Effective with improvement | Objective substantially achieved; minor gaps do not materially undermine outcomes. |
| Partially effective        | Control exists but material design/operation gaps reduce reliability.              |
| Ineffective                | Control absent, routinely bypassed, or not capable of achieving the objective.     |
| Not applicable             | Control legitimately not applicable; rationale and approval recorded.              |

# 9. Detailed Control Implementation Profiles

The following profiles are normative implementation guidance for the minimum CS-AML v0.1 control catalogue. Organisations MAY implement different procedures if they achieve the same objective and retain demonstrable evidence of operation.

## 9.1 Governance Controls

### GOV-01 — Accountable ownership

| Field                     | Specification                                                                                            |
|---------------------------|----------------------------------------------------------------------------------------------------------|
| Control objective         | Accountable ownership                                                                                    |
| Normative requirement     | Every case SHALL have an accountable owner.                                                              |
| Risk addressed            | Prevent orphaned investigations, ambiguous authority, and decisions without a clearly responsible human. |
| Primary roles             | Case owner; Investigation lead; Governance approver                                                      |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate.                   |

#### Implementation requirements

- Create a named Case Owner role at case opening.
- Record owner, deputy, approving manager, and review date in the Case Charter.
- Require transfer-of-ownership records when responsibility changes.
- Ensure the owner has authority to pause, narrow, escalate, or close the case.

#### Minimum evidence of operation

- Case Charter
- Case register
- Ownership transfer log
- Gate approval records

#### Assurance test

- Sample open cases and verify a current owner is recorded.
- Compare ownership changes with audit events.
- Interview analysts to confirm decision authority is understood.

#### Common failure modes

- Cases assigned to teams rather than accountable persons.
- Owner listed but lacking authority.
- Ownership changes without recorded rationale.

Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For



GOV-01, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

## GOV-02 — Conflict control

| Field                     | Specification                                                                                                                                                  |
|---------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Control objective         | Conflict control                                                                                                                                               |
| Normative requirement     | Material conflicts SHALL be declared and managed.                                                                                                              |
| Risk addressed            | Protect analytical independence where personal, organisational, donor, political, financial, or partnership interests could influence investigation decisions. |
| Primary roles             | All investigators; Case owner; Governance approver                                                                                                             |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate.                                                                         |

### Implementation requirements

- Require conflict declarations at intake and before high-impact dissemination.
- Define recusal, secondary review, and transfer procedures.
- Record both actual and reasonably perceived conflicts.
- Do not disclose protected-source identity unnecessarily when assessing conflicts.

### Minimum evidence of operation

- Conflict declaration
- Conflict register
- Recusal/mitigation record
- Independent review sign-off

### Assurance test

- Review a sample of high-impact cases for conflict declarations.
- Check declared conflicts against mitigation actions.
- Test whether conflicted reviewers were excluded from approvals.

### Common failure modes

- No declaration process.
- Conflicts considered only after publication.
- Informal mitigation with no evidence.

## Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For GOV-02, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

## 9.2 Case Management Controls

### CAS-01 — Defined purpose

| Field                     | Specification                                                                                                 |
|---------------------------|---------------------------------------------------------------------------------------------------------------|
| Control objective         | Defined purpose                                                                                               |
| Normative requirement     | Every case SHALL have a documented investigation question and scope.                                          |
| Risk addressed            | Prevent open-ended surveillance, mission creep, and evidence collection without a defined legitimate purpose. |
| Primary roles             | Case owner; Analyst; Approver                                                                                 |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate.                        |

#### Implementation requirements

- Create an Investigation Charter before substantive collection.
- State the issue, question, subjects, time period, jurisdiction, inclusion/exclusion boundaries, intended outputs, and stop conditions.
- Record material scope changes and require re-approval when risk increases.

#### Minimum evidence of operation

- Investigation Charter
- Scope-change record
- Investigation question
- Closure decision

#### Assurance test

- Verify each sampled case has a question framed without presuming guilt.
- Compare collected data with approved scope.
- Inspect scope changes after discovery of new subjects.

#### Common failure modes

- Question framed as an accusation.
- No geographic/time boundary.
- Collection expands without updated charter.

#### Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For CAS-01, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

## CAS-02 — Gate approval

| Field                     | Specification                                                                                                                       |
|---------------------------|-------------------------------------------------------------------------------------------------------------------------------------|
| Control objective         | Gate approval                                                                                                                       |
| Normative requirement     | High-risk cases SHALL pass defined lifecycle gates.                                                                                 |
| Risk addressed            | Ensure increasing analytical, privacy, legal, reputational, and safety risk receives proportionate review before the case advances. |
| Primary roles             | Case owner; Privacy/security reviewer; Independent approver                                                                         |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate.                                              |

### Implementation requirements

- Apply G0-G6 stage gates defined in the Investigation Methodology.
- Define criteria for high-risk cases, including sensitive personal data, protected sources, high-impact allegations, vulnerable persons, and planned public attribution.
- Record gate decision, approver, conditions, and unresolved gaps.

### Minimum evidence of operation

- Gate checklist
- Approval record
- Risk review
- Conditions/waivers

### Assurance test

- Trace sample cases through required gates.
- Confirm gate approvals predate the controlled action.
- Check that conditions were resolved or explicitly accepted.

### Common failure modes

- Retroactive approvals.
- Same person self-approves high-impact gates.
- Gate used as paperwork only.

### Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For CAS-02, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

## 9.3 Sources Controls

### SRC-01 — Provenance

| Field                     | Specification                                                                                                                                    |
|---------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|
| Control objective         | Provenance                                                                                                                                       |
| Normative requirement     | Material sources SHALL have provenance metadata.                                                                                                 |
| Risk addressed            | Allow another analyst to determine where information originated, how it was obtained, when it was accessed, and whether it remains reproducible. |
| Primary roles             | Collector; Analyst; Evidence custodian                                                                                                           |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate.                                                           |

#### Implementation requirements

- Register every material source with source ID, origin, publisher/owner where known, access method, access time, URL/location, archival copy where appropriate, legal/access note, and handling classification.
- Preserve original context and avoid detached screenshots when a fuller record is available.

#### Minimum evidence of operation

- Source register
- Archived copy
- Collection metadata
- Access/legal note

#### Assurance test

- Select material claims and trace them to registered sources.
- Verify URLs/locations and access dates are present.
- Check archived copy policy for mutable web content.

#### Common failure modes

- Screenshots with no URL/date.
- Copied text with no original context.
- Sources referenced only in analyst notes.

#### Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For SRC-01, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

## SRC-02 — Reliability assessment

| Field                     | Specification                                                                                                                                                           |
|---------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Control objective         | Reliability assessment                                                                                                                                                  |
| Normative requirement     | Material source reliability SHOULD be assessed separately from information credibility.                                                                                 |
| Risk addressed            | Avoid treating a generally reputable source as proof that every item it contains is accurate, or dismissing useful information solely because the source is unfamiliar. |
| Primary roles             | Analyst; Reviewer                                                                                                                                                       |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate.                                                                                  |

### Implementation requirements

- Use the CS-AML source reliability scale A-F and information credibility scale 1-6 where material.
- Document rationale for ratings that materially influence an assessment.
- Reassess when corroboration or contradiction emerges.

### Minimum evidence of operation

- Source rating
- Credibility rating
- Rating rationale
- Reassessment history

### Assurance test

- Check that source and information ratings are not conflated.
- Review whether high-impact claims rely on weak/unknown sources without corroboration.

### Common failure modes

- Everything from official sources marked A1 automatically.
- Anonymous source treated as unreliable without assessing the information.

### Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For SRC-02, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

## 9.4 Evidence Controls

### EVD-01 — Integrity

| Field             | Specification |
|-------------------|---------------|
| Control objective | Integrity     |

| Field                     | Specification                                                                                                 |
|---------------------------|---------------------------------------------------------------------------------------------------------------|
| Normative requirement     | Critical digital evidence SHOULD be integrity-protected.                                                      |
| Risk addressed            | Preserve the ability to demonstrate that critical digital material has not silently changed since collection. |
| Primary roles             | Evidence custodian; Collector; Security administrator                                                         |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate.                        |

#### Implementation requirements

- Preserve originals read-only where feasible.
- Compute cryptographic hashes for critical files at acquisition or entry into the evidence store.
- Record acquisition time, collector, source, and hash algorithm.
- Use derivative working copies rather than editing originals.

#### Minimum evidence of operation

- Hash record
- Original evidence store
- Acquisition log
- Read-only/immutability configuration

#### Assurance test

- Recompute hashes for a sample.
- Confirm analyst work occurs on derivatives.
- Check that replaced files create new versions rather than overwriting originals.

#### Common failure modes

- Original PDFs annotated directly.
- No distinction between original and working copy.
- Hashes calculated only at case closure.

### Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For EVD-01, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

### EVD-02 — Derivative lineage

| Field                 | Specification                                                                                               |
|-----------------------|-------------------------------------------------------------------------------------------------------------|
| Control objective     | Derivative lineage                                                                                          |
| Normative requirement | Derived artefacts SHALL link to their originals.                                                            |
| Risk addressed        | Ensure extracts, translations, cropped images, parsed tables, OCR text, and analyst-created datasets remain |

| Field                     | Specification                                                                          |
|---------------------------|----------------------------------------------------------------------------------------|
|                           | traceable to the source evidence from which they were produced.                        |
| Primary roles             | Analyst; Evidence custodian                                                            |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate. |

#### Implementation requirements

- Assign IDs to derivative artefacts.
- Record parent evidence reference, transformation type, tool/version when material, creator, and creation time.
- Do not replace original wording with corrected or translated text without retaining both.

#### Minimum evidence of operation

- Evidence lineage
- Derivative metadata
- Transformation log

#### Assurance test

- Trace sample extracts backward to originals.
- Check translations retain source text and translator/method metadata.

#### Common failure modes

- Orphan spreadsheets.
- OCR text treated as original.
- Translated quotes without source-language text.

### Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For EVD-02, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

## 9.5 Entities Controls

### ENT-01 — Evidence-based resolution

| Field                 | Specification                                                                                                                             |
|-----------------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| Control objective     | Evidence-based resolution                                                                                                                 |
| Normative requirement | Material entity merges SHALL be evidence-based and reversible.                                                                            |
| Risk addressed        | Prevent false network connections caused by prematurely treating similar names, addresses, identifiers, or profiles as the same person or |

| Field                     | Specification                                                                          |
|---------------------------|----------------------------------------------------------------------------------------|
|                           | organisation.                                                                          |
| Primary roles             | Analyst; Entity reviewer; Data steward                                                 |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate. |

#### Implementation requirements

- Maintain candidate-match state before merge.
- Record match features, conflicting features, confidence, analyst rationale, and evidence references.
- Support unmerge or superseding decisions without losing history.
- Do not merge solely on common names.

#### Minimum evidence of operation

- Entity-resolution decision
- Merge history
- Candidate match record
- Evidence links

#### Assurance test

- Review merged high-impact entities and verify multiple discriminating attributes.
- Test reversibility.
- Search for merges based only on name.

#### Common failure modes

- One-record-per-name logic.
- Hidden merges.
- Merged entity loses alternate identifiers/provenance.

### Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For ENT-01, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

## 9.6 Relationships Controls

### REL-01 — Relationship proof

| Field                 | Specification                                                                                    |
|-----------------------|--------------------------------------------------------------------------------------------------|
| Control objective     | Relationship proof                                                                               |
| Normative requirement | Material analytical relationships SHALL link to evidence and carry temporal/confidence metadata. |
| Risk addressed        | Prevent visual graph edges from being mistaken for                                               |



| Field                     | Specification                                                                          |
|---------------------------|----------------------------------------------------------------------------------------|
|                           | established relationships merely because they appear connected.                        |
| Primary roles             | Analyst; Graph/data steward                                                            |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate. |

#### Implementation requirements

- Represent relationships as first-class records, not display-only edges.
- Record relationship type, endpoints, source/evidence, valid time where known, confidence, status, and analyst.
- Use controlled vocabulary.
- Distinguish asserted, observed, inferred, and disputed relationships where needed.

#### Minimum evidence of operation

- Relationship record
- Edge provenance
- Graph audit
- Confidence metadata

#### Assurance test

- Click/trace sample material graph edges to evidence.
- Check historical relationships include valid time.
- Look for unsupported edges created manually in visualisation.

#### Common failure modes

- Graph edge with no provenance.
- Current director relationship shown as timeless.
- Association inferred from co-occurrence only.

### Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For REL-01, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

## 9.7 Assets Controls

### AST-01 — Attribution distinction

| Field                 | Specification                                                                                         |
|-----------------------|-------------------------------------------------------------------------------------------------------|
| Control objective     | Attribution distinction                                                                               |
| Normative requirement | Legal ownership, beneficial ownership, control, use, and association SHALL be represented distinctly. |

| Field                     | Specification                                                                                                                |
|---------------------------|------------------------------------------------------------------------------------------------------------------------------|
| Risk addressed            | Avoid overstating that a subject owns an asset merely because they use, control, finance, occupy, or are associated with it. |
| Primary roles             | Analyst; Reviewer; Legal/editorial reviewer where applicable                                                                 |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate.                                       |

#### Implementation requirements

- Use separate relationship types for legal title, beneficial interest, control, use/occupancy, financing, and association.
- Record valuation source/date and uncertainty separately from ownership.
- Require stronger review before public statements of beneficial ownership.

#### Minimum evidence of operation

- Asset record
- Ownership/control records
- Valuation provenance
- Assessment wording

#### Assurance test

- Compare graph labels with underlying attribution type.
- Review publications for language stronger than recorded evidence.

#### Common failure modes

- “Associated with” converted to “owns”.
- Asset value presented without date/source.
- Beneficial ownership inferred solely from family relationship.

### Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For AST-01, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

## 9.8 Value Flow Controls

### VAL-01 — Flow epistemic status

| Field                 | Specification                                                                           |
|-----------------------|-----------------------------------------------------------------------------------------|
| Control objective     | Flow epistemic status                                                                   |
| Normative requirement | Direct, documented, reconstructed, and hypothetical value flows SHALL be distinguished. |

| Field                     | Specification                                                                                                       |
|---------------------------|---------------------------------------------------------------------------------------------------------------------|
| Risk addressed            | Prevent analytical reconstruction from being presented as if it were a known bank transaction or verified transfer. |
| Primary roles             | Analyst; Reviewer; UI/data owner                                                                                    |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate.                              |

#### Implementation requirements

- Set flow\_class on every material ValueFlow.
- DIRECT requires direct transaction-level evidence; DOCUMENTED requires reliable documentation of the transfer/value movement; RECONSTRUCTED represents analytical linkage from multiple facts; HYPOTHETICAL is a scenario for testing only.
- Use distinct visual styling and narrative language for each class.
- Record amount/date uncertainty explicitly.

#### Minimum evidence of operation

- ValueFlow record
- Flow-class field
- Evidence links
- Visualisation legend

#### Assurance test

- Sample flows and verify classification against evidence.
- Check reports/graphs preserve class distinction.
- Review whether hypothetical flows leaked into findings.

#### Common failure modes

- All arrows look identical.
- Reconstructed contract-to-asset chain called a transfer.
- Estimated values displayed as exact.

### Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For VAL-01, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

## 9.9 Typologies Controls

### TYP-01 — Typology caution

| Field             | Specification    |
|-------------------|------------------|
| Control objective | Typology caution |

| Field                     | Specification                                                                                                            |
|---------------------------|--------------------------------------------------------------------------------------------------------------------------|
| Normative requirement     | A typology match SHALL NOT be treated as proof of money laundering or predicate crime.                                   |
| Risk addressed            | Use typologies as structured analytical lenses without converting pattern similarity into a determination of wrongdoing. |
| Primary roles             | Analyst; Peer reviewer                                                                                                   |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate.                                   |

#### Implementation requirements

- Use the CS-AML Typology Catalogue entry ID and indicator classes.
- Record supporting, contextual, disconfirming indicators and intelligence gaps.
- Require corroboration before assessments above Plausible consistency unless direct authoritative evidence establishes the mechanism.
- Document legitimate alternative explanations.

#### Minimum evidence of operation

- Typology worksheet
- Indicator map
- Alternative explanation
- Assessment language

#### Assurance test

- Review a sample of typology matches for disconfirming indicators.
- Search products for deterministic phrases unsupported by adjudicated facts.

#### Common failure modes

- Single red flag equals typology match.
- Typology label used as allegation.
- No alternatives considered.

#### Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For TYP-01, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

## 9.10 Hypotheses Controls

### HYP-01 — Competing explanations

| Field             | Specification          |
|-------------------|------------------------|
| Control objective | Competing explanations |

| Field                     | Specification                                                                              |
|---------------------------|--------------------------------------------------------------------------------------------|
| Normative requirement     | Material investigations SHOULD maintain plausible competing hypotheses.                    |
| Risk addressed            | Reduce confirmation bias and make analytical reasoning explicit, testable, and reviewable. |
| Primary roles             | Analyst; Peer reviewer                                                                     |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate.     |

#### Implementation requirements

- Create hypothesis records with supporting, contradicting, and unknown evidence.
- Include a legitimate/non-criminal explanation where plausible.
- Update status as evidence changes.
- Avoid deleting rejected hypotheses; retain decision history.

#### Minimum evidence of operation

- Hypothesis matrix
- Status history
- Evidence links

#### Assurance test

- Check high-impact cases for more than one plausible hypothesis.
- Verify rejected hypotheses show rationale.

#### Common failure modes

- Only inculpatory hypothesis exists.
- Hypothesis rewritten after evidence arrives to appear correct.

### Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For HYP-01, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

### HYP-02 — Disconfirmation

| Field                 | Specification                                                                                  |
|-----------------------|------------------------------------------------------------------------------------------------|
| Control objective     | Disconfirmation                                                                                |
| Normative requirement | High-impact adverse findings SHALL document reasonable efforts to find disconfirming evidence. |
| Risk addressed        | Prevent strong conclusions from being produced solely by accumulating confirmatory material.   |
| Primary roles         | Lead analyst; Independent reviewer                                                             |

| Field                     | Specification                                                                          |
|---------------------------|----------------------------------------------------------------------------------------|
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate. |

#### Implementation requirements

- Define what evidence would weaken or falsify each material hypothesis.
- Perform targeted searches for legitimate explanations, contradictory records, timing inconsistencies, identity mismatches, and alternative controllers/owners.
- Record searches even when no disconfirming evidence is found.

#### Minimum evidence of operation

- Disconfirmation log
- Search notes
- Hypothesis matrix
- Peer-review checklist

#### Assurance test

- Inspect high-impact findings for explicit disconfirmation actions.
- Assess whether searches were meaningful rather than ceremonial.

#### Common failure modes

- “No contradiction found” with no search record.
- Only sources likely to confirm the hypothesis are used.

### Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For HYP-02, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

## 9.11 Assessment Controls

### ASM-01 — Confidence statement

| Field                     | Specification                                                                                                                 |
|---------------------------|-------------------------------------------------------------------------------------------------------------------------------|
| Control objective         | Confidence statement                                                                                                          |
| Normative requirement     | Material assessments SHALL carry an explicit confidence level and basis.                                                      |
| Risk addressed            | Communicate the strength and limitations of analytical judgments so readers do not interpret all findings as equally certain. |
| Primary roles             | Analyst; Reviewer                                                                                                             |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate.                                        |

### Implementation requirements

- Use controlled confidence levels (e.g., Low/Moderate/High) with documented basis.
- Base confidence on evidence quality, corroboration, inference distance, unresolved contradictions, and intelligence gaps—not merely number of sources.
- Separate confidence in identity, relationship, flow, typology, and overall judgment where materially different.

### Minimum evidence of operation

- Assessment record
- Confidence rationale
- Evidence matrix

### Assurance test

- Compare confidence level with source quality and gaps.
- Check for high confidence despite unresolved identity or provenance issues.

### Common failure modes

- Numeric score with no explanation.
- High confidence because many articles repeat the same claim.

### Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For ASM-01, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

### GAP-01 — Explicit unknowns

| Field                     | Specification                                                                                         |
|---------------------------|-------------------------------------------------------------------------------------------------------|
| Control objective         | Explicit unknowns                                                                                     |
| Normative requirement     | Material intelligence gaps SHALL be explicit and linked to affected judgments.                        |
| Risk addressed            | Make clear what is not known and prevent absence of data from being mistaken for evidence of absence. |
| Primary roles             | Analyst; Reviewer                                                                                     |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate.                |

### Implementation requirements

- Maintain a gap register with gap description, impact, priority, possible collection path, legal/ethical constraints, and status.
- Link gaps to hypotheses, assessments, or value flows they affect.
- Carry critical unresolved gaps into intelligence products.

### Minimum evidence of operation

- Intelligence Gap Register
- Assessment limitations
- Collection plan

### Assurance test

- Select key judgments and verify critical unknowns are visible.
- Check closed gaps have supporting evidence.

### Common failure modes

- Unknown source of funds omitted.
- Bank data unavailable but flow written as complete.

**Implementation maturity**

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For GAP-01, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

## 9.12 Privacy Controls

### PRI-01 — Data minimisation

| Field                     | Specification                                                                                                        |
|---------------------------|----------------------------------------------------------------------------------------------------------------------|
| Control objective         | Data minimisation                                                                                                    |
| Normative requirement     | Sensitive personal data SHALL be necessary, proportionate, and relevant to an approved investigation purpose.        |
| Risk addressed            | Limit harm, legal exposure, and surveillance creep by collecting only data that materially serves the investigation. |
| Primary roles             | Case owner; Privacy reviewer; Collector                                                                              |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate.                               |

### Implementation requirements

- Apply necessity/relevance test before collecting or retaining sensitive data.
- Document justification for special-category/sensitive financial or protected-source information.
- Avoid collecting relatives, associates, contacts, or location history merely because technically available.
- Use redaction/pseudonymisation where identity is not required.

### Minimum evidence of operation

- Collection decision
- Privacy review



- Data inventory
- Redaction record

#### Assurance test

- Compare collected sensitive fields with case purpose.
- Sample unrelated persons for documented necessity.
- Check bulk imports for minimisation controls.

#### Common failure modes

- “May be useful later” as sole justification.
- Whole datasets retained when only a few records are relevant.

### Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For PRI-01, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

### PRI-02 — Retention and disposition

| Field                     | Specification                                                                                                            |
|---------------------------|--------------------------------------------------------------------------------------------------------------------------|
| Control objective         | Retention and disposition                                                                                                |
| Normative requirement     | Sensitive data SHALL have retention, review, and disposition rules.                                                      |
| Risk addressed            | Prevent indefinite accumulation of personal data and ensure closed-case material is retained only for justified periods. |
| Primary roles             | Data steward; Privacy reviewer; Evidence custodian                                                                       |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate.                                   |

#### Implementation requirements

- Assign retention class at ingestion or case association.
- Define review triggers, legal holds, archival criteria, deletion/anonymisation methods, and exceptions.
- Log destruction or irreversible anonymisation.
- Protect evidence that must be preserved from premature deletion.

#### Minimum evidence of operation

- Retention schedule
- Disposition log
- Legal hold record
- Retention review

#### Assurance test

- Identify expired items and verify disposition occurred.
- Review exceptions for approvals and reasons.

#### Common failure modes

- Everything retained indefinitely.
- Manual deletion with no audit.
- Retention policy exists but no job/workflow implements it.

#### Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For PRI-02, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

## 9.13 Security Controls

### SEC-01 — Least privilege

| Field                     | Specification                                                                              |
|---------------------------|--------------------------------------------------------------------------------------------|
| Control objective         | Least privilege                                                                            |
| Normative requirement     | Access SHALL be role- and need-based.                                                      |
| Risk addressed            | Reduce insider risk and unnecessary exposure of sensitive case, source, and personal data. |
| Primary roles             | Security administrator; Case owner; Data owner                                             |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate.     |

#### Implementation requirements

- Define roles and data-access attributes.
- Separate ordinary case access from protected-source identity, highly sensitive evidence, and dissemination authority.
- Review access periodically and on role change.
- Use strong authentication and log privileged actions.

#### Minimum evidence of operation

- Access-control matrix
- IAM configuration
- Access review
- Privileged audit log

#### Assurance test

- Sample users and compare permissions with role.
- Test terminated/transferred users.

- Review dormant privileged accounts.

#### Common failure modes

- All investigators are administrators.
- Shared accounts.
- Case access never expires.

### Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For SEC-01, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

## SEC-02 — Protected-source compartmentalisation

| Field                     | Specification                                                                                                              |
|---------------------------|----------------------------------------------------------------------------------------------------------------------------|
| Control objective         | Protected-source compartmentalisation                                                                                      |
| Normative requirement     | Protected source identities SHALL be compartmentalised from ordinary case material.                                        |
| Risk addressed            | Reduce risk that compromise, sharing, publication, or broad team access reveals whistleblowers or confidential informants. |
| Primary roles             | Source handler; Security administrator; Case owner                                                                         |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate.                                     |

#### Implementation requirements

- Use source aliases in general case records.
- Store identifying data in a restricted compartment with separate permissions.
- Minimise cross-links that expose identity.
- Define controlled re-identification process and emergency disclosure rules.

#### Minimum evidence of operation

- Restricted source store
- Alias mapping
- Access log
- Re-identification approval

#### Assurance test

- Verify ordinary analysts cannot retrieve source identity without authorisation.
- Check exports/publication packages for leakage.

#### Common failure modes

- Source name embedded in filenames.
- Identity repeated in notes and chat.

- Alias mapping stored beside public product.

### Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For SEC-02, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

## 9.14 Quality Controls

### QUA-01 — Independent peer review

| Field                     | Specification                                                                                                               |
|---------------------------|-----------------------------------------------------------------------------------------------------------------------------|
| Control objective         | Independent peer review                                                                                                     |
| Normative requirement     | High-impact products SHALL be independently reviewed before external dissemination.                                         |
| Risk addressed            | Detect analytical error, unsupported inference, overstatement, privacy harm, and inconsistent application of the framework. |
| Primary roles             | Peer reviewer; Approver; Lead analyst                                                                                       |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate.                                      |

#### Implementation requirements

- Define high-impact criteria.
- Reviewer SHALL be sufficiently independent from primary analysis.
- Review provenance, entity resolution, key relationships, flow classification, typology use, alternatives, confidence, gaps, privacy, and wording.
- Material reviewer disagreements SHALL be resolved or recorded.

#### Minimum evidence of operation

- Peer-review form
- Reviewer comments
- Resolution log
- Approval record

#### Assurance test

- Reperform selected key judgments from evidence.
- Check reviewer independence and timing.
- Verify disagreements were not silently removed.

#### Common failure modes

- Copy-editing mistaken for analytical review.
- Reviewer approves without evidence access.

## Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For QUA-01, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

## 9.15 Dissemination Controls

### DIS-01 — Handling and approval

| Field                     | Specification                                                                                                                |
|---------------------------|------------------------------------------------------------------------------------------------------------------------------|
| Control objective         | Handling and approval                                                                                                        |
| Normative requirement     | External dissemination SHALL have classification, audience, purpose, and approval recorded.                                  |
| Risk addressed            | Prevent intelligence products from reaching audiences that lack need, context, legal basis, or adequate handling capability. |
| Primary roles             | Product owner; Approver; Security/privacy reviewer                                                                           |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate.                                       |

#### Implementation requirements

- Classify product and define intended audience/use.
- Apply redaction, minimisation, source protection, and caveats appropriate to recipient.
- Record approval, recipient, date, version, transfer method, and restrictions.
- Create separate referral and public versions where necessary.

#### Minimum evidence of operation

- Dissemination log
- Approved product version
- Recipient restrictions
- Transfer record

#### Assurance test

- Match sent files to approved hashes/versions.
- Verify recipients and restrictions.
- Check whether superseded drafts were shared.

#### Common failure modes

- Emailing working files.
- No record of who received which version.
- Same product sent to FIU and published publicly.

## Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For DIS-01, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

## 9.16 Audit Controls

### AUD-01 — Material change auditability

| Field                     | Specification                                                                           |
|---------------------------|-----------------------------------------------------------------------------------------|
| Control objective         | Material change auditability                                                            |
| Normative requirement     | Material analytical and evidentiary changes SHOULD be logged.                           |
| Risk addressed            | Allow reconstruction of how the case changed and who made decisions affecting findings. |
| Primary roles             | System owner; Security; Assurance reviewer                                              |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate.  |

#### Implementation requirements

- Audit creation/update/deletion/merge/unmerge of material entities, evidence metadata, relationships, hypotheses, assessments, approvals, dissemination, and access to highly sensitive records.
- Protect logs from routine user alteration.
- Synchronise time sources where practical.

#### Minimum evidence of operation

- Audit trail
- Version history
- Log-retention policy
- Integrity monitoring

#### Assurance test

- Trace a sample material change end-to-end.
- Check logs identify actor, time, object, action, and previous/new state where required.

#### Common failure modes

- Only login events logged.
- Analysts can edit audit logs.
- No history after entity merge.

## Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For AUD-01, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

## 9.17 Technology Controls

### TEC-01 — AI verification

| Field                     | Specification                                                                                                                 |
|---------------------------|-------------------------------------------------------------------------------------------------------------------------------|
| Control objective         | AI verification                                                                                                               |
| Normative requirement     | AI-generated material SHALL NOT become a material fact without human verification against authoritative or primary evidence.  |
| Risk addressed            | Prevent hallucinated, decontextualised, or misattributed model output from contaminating evidentiary records and assessments. |
| Primary roles             | Analyst; Technology owner; Reviewer                                                                                           |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate.                                        |

#### Implementation requirements

- Label AI-assisted outputs.
- Require source-level human verification before promotion to Claim/Fact.
- Do not permit generative summaries to overwrite original evidence.
- Record model/tool use when material to reproducibility.
- Apply stricter controls to identity resolution, allegation drafting, translation, and extraction from sensitive records.

#### Minimum evidence of operation

- AI-use record
- Verification record
- Source links
- Prompt/output retention where policy permits

#### Assurance test

- Sample AI-assisted facts and reproduce verification.
- Search for facts whose only provenance is an AI output.

#### Common failure modes

- LLM answer cited as source.
- AI confidence treated as analytical confidence.
- Unverified OCR/translation promoted to fact.

## Implementation maturity

Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For TEC-01, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

### TEC-02 — Explainable automation

| Field                     | Specification                                                                                                                   |
|---------------------------|---------------------------------------------------------------------------------------------------------------------------------|
| Control objective         | Explainable automation                                                                                                          |
| Normative requirement     | Automated scores or models used materially SHOULD be explainable and governed.                                                  |
| Risk addressed            | Ensure risk scores, entity matching, anomaly flags, and typology ranking can be understood, challenged, validated, and changed. |
| Primary roles             | Model owner; Analyst; Independent validator                                                                                     |
| Default trigger/frequency | At each relevant case event; continuous/system-enforced where technically appropriate.                                          |

#### Implementation requirements

- Document purpose, input features/data, output meaning, thresholds, version, known limitations, owner, validation status, and override process.
- Do not use a score as a substitute for assessment.
- Monitor drift and false positives where outcomes are available.

#### Minimum evidence of operation

- Model/rule card
- Validation record
- Threshold rationale
- Override log
- Performance metrics

#### Assurance test

- Select material automated outcomes and explain why they occurred.
- Check model version used at decision time.
- Review overrides for patterns.

#### Common failure modes

- Black-box score with no feature explanation.
- Threshold chosen only to reduce workload.
- Model changes without versioning.

## Implementation maturity



Baseline: documented and consistently performed. Managed: system-supported, measured, and exceptions tracked. Assured: independently tested with remediation and periodic revalidation. For TEC-02, higher maturity SHALL NOT be achieved by indiscriminate collection or broader surveillance.

## 10. Cross-Control Implementation Bundles

### 10.1 New case baseline

Before substantive collection, assign owner, approve purpose/scope, establish source provenance, confirm necessary/proportionate collection, and restrict access.

Controls: GOV-01 CAS-01 SRC-01 PRI-01 SEC-01

### 10.2 Sensitive/protected-source case

Use enhanced gates, protected-source compartmentalisation, stricter access, retention decisions, and auditable handling.

Controls: GOV-01 CAS-02 PRI-01 PRI-02 SEC-01 SEC-02 AUD-01

### 10.3 Entity/graph investigation

Every merge, edge, asset attribution, and derived graph element remains evidence-linked and reversible.

Controls: SRC-01 EVD-02 ENT-01 REL-01 AST-01 AUD-01

### 10.4 Follow-the-value investigation

Clearly distinguish known transfer evidence from reconstructed economic relationships and carry gaps/confidence into the assessment.

Controls: VAL-01 REL-01 AST-01 HYP-01 GAP-01 ASM-01

### 10.5 High-impact adverse product

Require alternative explanations, disconfirmation, explicit confidence/gaps, independent review, and controlled dissemination.

Controls: GOV-02 CAS-02 TYP-01 HYP-01 HYP-02 ASM-01 GAP-01 QUA-01 DIS-01

### 10.6 AI/automation-assisted investigation

Verify model outputs against source evidence, preserve lineage/versioning, explain material scores, and independently review high-impact uses.

Controls: TEC-01 TEC-02 EVD-02 ENT-01 AUD-01 QUA-01

## 11. Exceptions and Compensating Controls

A control exception is not the absence of a control. It is a documented, risk-accepted deviation from the standard requirement. Exceptions SHALL be narrowly scoped and time-limited.

8. Identify the control and exact requirement not met.
9. Explain operational reason and affected cases/data.
10. Assess analytical, privacy, security, legal, source-safety, and reputational risk.
11. Define compensating control(s).
12. Obtain approval from a role independent of the person requesting the exception where practicable.
13. Set expiry/review date.

14. Record closure, extension, or conversion into a permanent control change.

**Not an exception**

Convenience, workload, urgency, donor pressure, publication deadlines, or technical difficulty alone do not justify silently bypassing a mandatory control.

12. Metrics and Control Effectiveness

Metrics SHALL be interpreted as evidence about outcomes, not targets that incentivise surveillance or accusation. Higher case volume, more entities, more alerts, or more typology matches are not measures of success.

| Domain                | Illustrative measures                                                                                     |
|-----------------------|-----------------------------------------------------------------------------------------------------------|
| Purpose/scope         | % cases with approved charter before substantive collection; number of scope-change exceptions.           |
| Provenance            | % material facts traceable to registered evidence; orphan derivative rate.                                |
| Entity quality        | Merge reversal rate; duplicate rate; high-impact merges independently reviewed.                           |
| Relationship quality  | % material edges with evidence; unsupported-edge defects found in QA.                                     |
| Value flow            | % material flows with explicit flow_class; reconstructed/direct misclassification findings.               |
| Analytical discipline | % high-impact cases with competing hypotheses/disconfirmation; unresolved critical gaps at dissemination. |
| Privacy               | Sensitive records collected without necessity rationale; retention exceptions; privacy incidents.         |
| Security              | Excess-access findings; protected-source access events; privileged account review completion.             |
| Quality               | Peer-review defect categories; material changes prompted by review; repeat findings.                      |
| Technology            | AI facts rejected at verification; model overrides; unexplained-score findings.                           |
| Dissemination         | Unapproved recipients/versions; redaction defects; dissemination withdrawal/correction events.            |

# 13. Assurance Programme

## 13.1 First-line self-check

Case teams perform control completion checks and correct obvious gaps before gate review or dissemination.

## 13.2 Independent quality review

Peer or specialist reviewers challenge evidence, reasoning, privacy, security, and product wording for high-impact cases.

## 13.3 Periodic control assurance

An organisational reviewer independent of day-to-day case work tests a sample of controls, documents findings, tracks remediation, and reports systemic issues to leadership.

## 13.4 Triggered assurance

- material correction or retraction
- source compromise or data breach
- serious unsupported allegation
- repeated entity-resolution errors
- major technology/model change
- external complaint indicating potential rights harm
- material control failure in a partner or shared investigation

# 14. Implementation Maturity Model

| Level                   | Characteristics                                                                                                                                           |
|-------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| L1 — Defined            | Named control owners; baseline policy/templates; minimum records exist; control operation largely manual.                                                 |
| L2 — Managed            | Controls integrated into case workflow; risk profiles, gate checks, access, retention, and review operate consistently; exceptions tracked.               |
| L3 — Measured           | Control coverage/outcomes are measured; recurring defects analysed; system validations reduce manual errors; independent testing occurs.                  |
| L4 — Assured & adaptive | Independent assurance, secure automation, model validation, trend analysis, cross-case learning, partner controls, and documented continuous improvement. |

**Maturity rule**

Higher maturity means better selectivity, provenance, challenge, safety, and decision usefulness—not greater data volume or more intrusive monitoring.

## 15. Minimum Organisational Implementation Plan

| Phase                                | Minimum deliverables                                                                                                                                          |
|--------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Phase A — Foundation                 | Adopt framework; nominate owner; approve roles; define P1-P4 profiles; establish case/source/evidence registers; implement least privilege.                   |
| Phase B — Analytical controls        | Implement entity resolution, relationship provenance, asset attribution, flow classification, typology worksheets, hypotheses, confidence, and gap registers. |
| Phase C — Protection & dissemination | Implement protected-source compartmentalisation, retention, high-impact peer review, dissemination logging, and incident response.                            |
| Phase D — Assurance & technology     | Implement audit events, periodic control testing, AI/model governance, metrics, and remediation tracking.                                                     |

## 16. Control Implementation Conformance

An organisation MAY claim conformance with this guide only for a stated scope (for example, a unit, programme, platform, or investigation function) and assessment period.

- All applicable mandatory controls have documented owners and procedures.
- Evidence demonstrates controls operated during the assessment period.
- Material exceptions are recorded, approved, and time-limited.
- High-impact cases meet enhanced review requirements.
- A risk-based control test has been completed and material deficiencies have remediation plans.
- The organisation does not claim conformance merely because templates or software features exist.

### 16.1 Minimum Conformance Evidence Pack

- Control register with owner/status
- Approved local implementation procedures
- Sample case charter and gate records
- Source/evidence provenance records
- Entity merge and relationship provenance records
- Value-flow classification records
- Hypothesis/assessment/gap artefacts
- Privacy and access evidence
- Peer-review and dissemination evidence
- Audit/event history
- Control test results
- Open exceptions and remediation register

# 17. Traceability to Other CS-AML Documents

| Document                          | Control-guide relationship                                                                                                              |
|-----------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------|
| Goals & Non-Goals                 | Defines why controls exist and what CS-AML must not become.                                                                             |
| Investigation Methodology         | Defines when controls operate across case stages and gates.                                                                             |
| Typology Catalogue                | Provides structured typology and indicator content governed by TYP-01 and related analytical controls.                                  |
| Data Model Specification          | Defines the canonical objects and metadata that store control evidence, provenance, confidence, privacy, audit, and analytical records. |
| Technology Architecture (planned) | Will define reference technical components used to implement security, workflow, graph, evidence, audit, model, and reporting controls. |

## Annex A — Control Register Template

| Control ID | Owner | Procedure | Profile | Frequency | Evidence | Status | Last test | Rating | Remediation |
|------------|-------|-----------|---------|-----------|----------|--------|-----------|--------|-------------|
|            |       |           |         |           |          |        |           |        |             |
|            |       |           |         |           |          |        |           |        |             |
|            |       |           |         |           |          |        |           |        |             |
|            |       |           |         |           |          |        |           |        |             |
|            |       |           |         |           |          |        |           |        |             |
|            |       |           |         |           |          |        |           |        |             |

## Annex B — Control Test Worksheet

| Field                   | Specification                                   |
|-------------------------|-------------------------------------------------|
| Control ID              |                                                 |
| Period / population     |                                                 |
| Tester / independence   |                                                 |
| Design effectiveness    | Effective / Improvement / Partial / Ineffective |
| Operating effectiveness | Effective / Improvement / Partial / Ineffective |
| Sample                  |                                                 |
| Exceptions              |                                                 |
| Root cause              |                                                 |
| Risk/impact             |                                                 |
| Remediation owner/date  |                                                 |
| Retest result           |                                                 |

## Annex C — Exception Record Template

| Field                 | Specification |
|-----------------------|---------------|
| Exception ID          |               |
| Control / requirement |               |
| Reason                |               |

| Field                | Specification |
|----------------------|---------------|
| Affected scope       |               |
| Risk assessment      |               |
| Compensating control |               |
| Approver             |               |
| Start / expiry       |               |
| Review result        |               |

## Annex D — High-Impact Product Control Checklist

- ☐ Case purpose/scope current
- ☐ Material facts trace to evidence
- ☐ Entity resolution rechecked
- ☐ Material relationships evidence-linked
- ☐ Asset attribution wording matches evidence
- ☐ Value flows correctly classified
- ☐ Typology not presented as proof
- ☐ Competing hypotheses considered
- ☐ Disconfirming search documented
- ☐ Confidence and basis explicit
- ☐ Critical gaps visible
- ☐ Sensitive data minimised
- ☐ Protected sources protected
- ☐ Independent peer review completed
- ☐ Dissemination version/audience approved



# Annex E — Reference Lineage

These external sources provide alignment context rather than direct regulatory obligations for civil-society organisations. CS-AML adapts their risk-based and effectiveness concepts to a rights-respecting investigative setting.

| Source          | Use in this guide                                                                                                                               |
|-----------------|-------------------------------------------------------------------------------------------------------------------------------------------------|
| FATF            | FATF Recommendations and 2022 Methodology, as amended June 2026 — risk-based approach and effectiveness principles.                             |
| Wolfsberg Group | Guidance on the Risk-Based Approach, June 2026 — proportionality, prioritisation, and effectiveness.                                            |
| PPATK           | Klinik Dumas Special Edition, November 2025 — role and quality of NGO/CSO and public information in supporting financial-intelligence analysis. |
| CS-AML          | Framework v0.1 Expanded; Goals & Non-Goals; Typology Catalogue; Investigation Methodology; Data Model Specification.                            |

## E.1 Interpretation notes

FATF materials inform the concepts of risk-based implementation and effectiveness. Wolfsberg materials inform proportionality, prioritisation, and outcome focus. PPATK materials support the premise that well-structured NGO/CSO information can contribute to financial-intelligence analysis. None of these references converts CS-AML users into regulated financial institutions or grants investigative powers reserved to competent authorities.